PROYECTO: SHIELD-PORT AI

Ecosistema de Defensa contra Ataques de Juice Jacking mediante IA y Criptografía

El Panorama Actual: Riesgos, Mitos y Realidades del Puerto USB

Antes de comprender la solución técnica, es vital entender el escenario al que nos enfrentamos. Hoy en día, existe la falsa creencia de que los ataques por USB (como el Juice Jacking) son un problema del pasado. La realidad es mucho más compleja.

La Ilusión de la Seguridad en Smartphones Modernos

Es cierto que los sistemas operativos móviles actuales (iOS y Android) han implementado barreras preventivas. Por defecto, un puerto USB solo permite la entrada de energía. Para que haya transmisión de datos o instalación de aplicaciones (.APK), el usuario debe:

- Desbloquear el teléfono con su PIN o biometría.
- Aceptar explícitamente un cuadro de diálogo ("¿Confiar en este ordenador?" o "Permitir transferencia de datos").
- Tener activada la Depuración USB (opción oculta para desarrolladores).

Además, en el mercado existen soluciones físicas de hardware como los **Data Blockers** (también llamados condones USB), adaptadores que literalmente cortan los pines de datos del cable, permitiendo solo el paso de electricidad.

Las Vulnerabilidades Reales (Donde los OS fallan)

Si los móviles están "protegidos", ¿dónde está el peligro real? El riesgo reside en tres vectores principales que los sistemas operativos no pueden detener:

A. Dispositivos sin "Sentido Común" (Cámaras, E-readers, IoT)

A diferencia de un iPhone, una cámara de fotos digital o un lector de libros electrónicos no tienen pantallas de permisos avanzadas. Si conectas una cámara a un puerto comprometido, el puerto puede montar la tarjeta MicroSD automáticamente. Un atacante puede inyectar scripts maliciosos directamente en la tarjeta de memoria en milisegundos. Cuando el usuario extraiga esa tarjeta y la conecte a su PC de casa para ver las fotos, el PC quedará infectado.

B. Ingeniería Social y Fatiga de Alertas

Los ciberdelincuentes saben que los usuarios no leen las alertas. Si al conectar el móvil en un aeropuerto, la pantalla de carga (que debería ser pasiva) muestra repentinamente un mensaje como: *"Error de carga de la Red WiFi Pública gratuita. Pulse Aceptar para continuar"*, el usuario, con prisa, pulsará "Aceptar". Al hacerlo, acaba de autorizar la apertura del canal de datos a un puerto atacante.

C. Dispositivos Públicos Interactivos

Las máquinas de revelado de fotos (Kioskos) donde insertamos nuestro USB o móvil son un vector de infección bidireccional masivo. Están diseñadas para tener el canal de datos abierto por defecto, siendo un paraíso para la propagación de malware.

> Es aquí donde nace la necesidad de Shield-Port AI: un sistema que no dependa del usuario ni de "reglas tontas", sino de una **Inteligencia Artificial que audite matemáticamente la conexión**.

Fase 3: Evolución a Arquitectura EDR Zero-Trust (La Versión Definitiva)

Si bien las fases anteriores demostraron que era posible bloquear ataques básicos mediante firmas HMAC y un sistema de puntuación heurística, los ciberdelincuentes modernos utilizan técnicas de ofuscación que evaden fácilmente estas reglas estáticas. En esta fase final, el proyecto Shield-Port AI abandona las reglas programadas a mano y adopta **matemáticas avanzadas y Machine Learning real**.

2.1 Evolución Criptográfica: De HMAC Estático a RSA Desafío-Respuesta

El problema de la versión anterior (Fase 2)

Utilizábamos una clave simétrica (`SECRET_KEY = b"mi_clave_secreta"`) programada directamente en el código fuente de ambos dispositivos. Esta práctica (Hardcoding) es una vulnerabilidad crítica. Si un atacante extrae el firmware del Escudo mediante ingeniería inversa, obtiene la clave y puede fabricar cables piratas indetectables. Además, una firma estática es vulnerable a ataques de repetición (Replay Attacks).

La Solución Innovadora (Fase 3)

Implementación del protocolo **Challenge-Response** utilizando criptografía asimétrica (RSA), el mismo estándar propuesto para la autenticación oficial de USB-C.

Cómo funciona el nuevo trazo de código:

1. **Sin secretos en el Escudo**
   El Escudo (PC) ya no almacena secretos. Solo posee una **Clave Pública**.
2. **Generación del Nonce**
   Al conectar el USB, el Escudo genera un Nonce (un número aleatorio de un solo uso generado por el sistema operativo: `os.urandom(16).hex()`).
3. **Envío del Desafío**
   El Escudo envía este Desafío al puerto: *"Firma este número exacto que acabo de crear"*.
4. **Firma con Clave Privada**
   El cargador legítimo utiliza su Clave Privada (almacenada en un chip físico inexpugnable) para firmar el Nonce y lo devuelve.
5. **Verificación Matemática**
   El Escudo lo verifica matemáticamente con `rsa.verify()`.

> ✅ **Mejora Operativa:** Inmunidad total contra ataques de clonación y repetición. Sin la clave privada física, es matemáticamente imposible superar el desafío.

2.2 Evolución de la IA: De Heurística a Machine Learning Estructural

El problema de la versión anterior (Fase 2)

El "Motor de IA" era en realidad un sistema experto basado en sentencias estáticas (ej. `if bNumInterfaces > 1: puntos_riesgo += 40`). Un atacante sofisticado (mediante un cable O.MG o un clonador USB) puede falsificar su identidad para que parezca un cargador perfecto (Clase 0) y luego inyectar malware en silencio tras conseguir el permiso del usuario (Ingeniería Social), burlando completamente el sistema de puntos.

La Solución Innovadora (Fase 3)

Sustitución del sistema de puntos por un modelo de Machine Learning no supervisado (**Isolation Forest** de la librería `scikit-learn`) que analiza la geometría matemática del tráfico de datos en caliente.

La Matemática detrás del Código: Entropía de Shannon

En lugar de leer etiquetas o buscar "firmas de virus conocidos", el sistema intercepta los datos y extrae "Características" (Features). La principal es la **Entropía de Shannon**, que mide el nivel de caos o aleatoriedad de la información:

$$H(X) = -\sum_{i=1}^{n} P(x_i) \log_2 P(x_i)$$

¿Qué significa esta ecuación? La Entropía de Shannon $H(X)$ cuantifica la incertidumbre o aleatoriedad de un conjunto de datos. Cada $P(x_i)$ es la probabilidad de que aparezca el símbolo x_i. Si todos los bytes son iguales (datos muy predecibles), la entropía es **0** (sin caos). Si todos los bytes son completamente aleatorios (como en un archivo cifrado o malware ofuscado), la entropía se acerca a su valor máximo de **8 bits**. En resumen: **alta entropía = datos muy aleatorios = posible amenaza**.

El refinamiento mediante Varianza

Para evitar Falsos Positivos (ej. bloquear una simple foto porque tiene alta entropía al estar comprimida de forma legítima), el código divide el archivo en "ventanas deslizantes" (chunks) de 64 bytes y calcula la **Varianza del Caos** entre ellas.

Archivo Legítimo

Un archivo legítimo (un .APK normal o un .JPG de la cámara) tiene una estructura de compresión uniforme (**varianza cercana a 0.0**).

Malware Ofuscado

Un ataque políglota o un malware ofuscado escondido tras un NOP Sled (relleno de ceros) provoca un **salto brusco de entropía**, disparando la varianza matemática.

Veredicto de la Red Neuronal

El modelo Isolation Forest traza una frontera de decisión en un espacio tridimensional: **[Entropía, Varianza, Tamaño]**. Si el vector del tráfico cae fuera de esta "nube de normalidad", la IA lo clasifica instantáneamente como una anomalía (`-1`) y se destruye el canal de datos a nivel de socket.

2.3 Auditoría Forense y Gemelo Digital & 2.4 Limitaciones del Sistema Actual

2.3 Auditoría Forense y Gemelo Digital

Para dotar al proyecto de rigor científico y validez probatoria, se ha añadido un módulo de registro automático forense (`guardar_en_csv()`).

📝 **Mejora Operativa:** Toda decisión tomada por la red neuronal se documenta en un archivo `registro_auditoria_ia.csv` con sellado de tiempo, mostrando los valores exactos de entropía, varianza y el veredicto. Esto demuestra empíricamente la eficacia del sistema ante ataques de inyección de código y ofuscación, un requisito vital para los **Centros de Operaciones de Seguridad (SOC)**.

2.4 Limitaciones del Sistema Actual

A pesar de la robustez arquitectónica, este laboratorio en Python presenta limitaciones propias de un entorno de simulación virtualizado (Gemelo Digital):

Espacio de Usuario vs. Espacio de Kernel

El Escudo intercepta el tráfico a nivel de red (Sockets TCP). En un despliegue de hardware físico real, este código debería reescribirse en C/C++ y compilarse como un **Driver de Filtro USB a nivel de Kernel** (o implementarse en hardware intermediario como una Raspberry Pi utilizando módulos como `libcomposite`) para permitir el corte de corriente o el bloqueo de los pines de datos físicos del conector USB.

Tolerancia del Machine Learning (Fine-Tuning)

El modelo Isolation Forest actual tiene una tasa de contaminación configurada de manera estricta al **1%** (`contamination=0.01`). En un entorno de producción masivo a nivel global, este porcentaje requeriría un **ajuste fino continuo** basado en grandes conjuntos de datos de telemetría para equilibrar la máxima seguridad con la fluidez en la experiencia del usuario (UX), evitando falsos negativos ante malware diseñado para tener una varianza artificialmente baja.

Conclusión del Proyecto

Shield-Port AI demuestra empíricamente que la defensa tradicional contra el Juice Jacking y las inyecciones por hardware está obsoleta. Confiar en la identidad declarada por un dispositivo USB o depender de pantallas de confirmación que los usuarios aprueban por inercia o engaño es insuficiente ante el hardware malicioso moderno.

> Mediante la creación de este Gemelo Digital, hemos validado la viabilidad de una arquitectura EDR (Endpoint Detection and Response) verdaderamente **Zero-Trust**.

Criptografía Asimétrica Inquebrantable

Para verificar la autenticidad de los chips de hardware, anulando los ataques de clonación física.

IA Conductual en Vivo

Para interceptar cargas útiles ofuscadas analizando la varianza de la Entropía de Shannon, neutralizando inyecciones de Zero-Days estructuradas.

Defensa en Profundidad

Protección de dispositivos sin pantalla y ecosistemas IoT, marcando el camino hacia la próxima generación de seguridad proactiva en puertos periféricos.

Esta solución **hibrida la criptografía asimétrica inquebrantable** (para verificar la autenticidad de los chips de hardware) con la **Inteligencia Artificial conductual en vivo** (para interceptar cargas útiles ofuscadas analizando la varianza de la Entropía de Shannon). Este enfoque de **"Defensa en Profundidad"** anula tanto los ataques de clonación física como las inyecciones de Zero-Days estructuradas en dispositivos sin pantalla, marcando el camino hacia la próxima generación de seguridad proactiva en puertos periféricos y ecosistemas IoT.